Building the Corporate Enterprise (Active Directory Hardening & Centralization)

Author: Bibek Pandeya

Environment: Active Directory Domain Services (bibek.local)

Target Infrastructure: Windows Server 2019 Datacenter / Standard, Windows 11 Enterprise Workstation

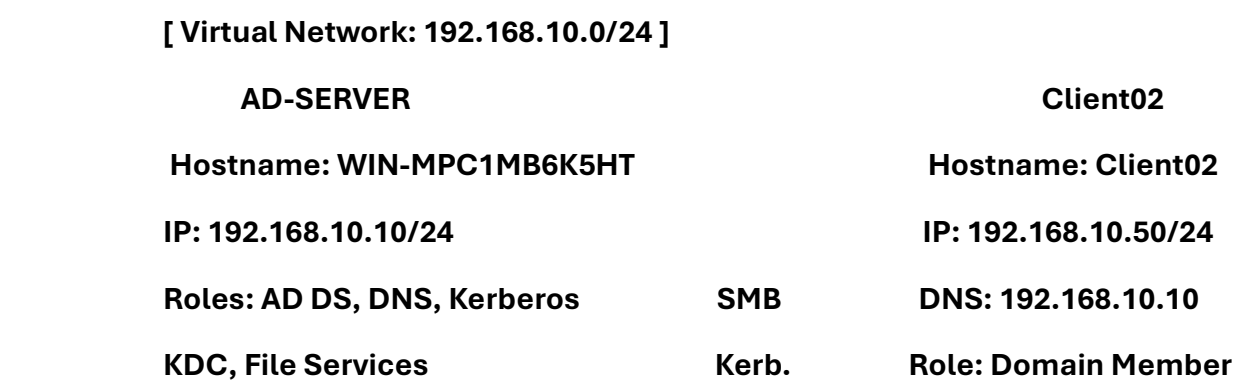
Executive Summary

A centralized, scalable, and cryptographically hardened Active Directory Domain Services (AD DS) infrastructure was designed, implemented, and validated. This rebuild deployed a dedicated primary Domain Controller running integrated Domain Name System (DNS) services, established Role-Based Access Control (RBAC) via targeted Organizational Units (OUs) and Security Groups, enforced strict file storage isolation via Access Control Lists (DACLs) under the principle of least privilege, centralized hardware and firewall restrictions through Group Policy Objects (GPOs), and eliminated legacy NTLM authentication across all network channels in favor of ticket-based Kerberos (AES-256).

1. Project Scope & Architecture Overview

The corporate enterprise topology was deployed using an isolated, private virtualized network segment with deterministic addressing:

Hostname	Operating System	IP Address	Subnet Mask	Role / Function
AD-SERVER (WIN-MPC1MB6K5HT)	Windows Server 2019	192.168.10.10	255.255.255.0	Primary Domain Controller (DC), DNS Server, KDC, SMB File Server
Client02 (Client-01)	Windows 11 Enterprise	192.168.10.50	255.255.255.0	Enterprise Managed Client Workstation



2. Phase-by-Phase Technical Implementation

Phase 1: Establish (Domains & DCs)

1. **Host Identity & Network Layer:** The primary server was configured with a static IPv4 address (192.168.10.10), loopback DNS binding (127.0.0.1), and an authoritative hostname *(See Appendix A: Figure 1)*.
2. **Directory Services Deployment:** The Active Directory Domain Services (AD DS) and DNS Server server roles were provisioned. The server was promoted to the forest root Domain Controller for the domain namespace bibek.local, instantiating the central Directory database file (C:\Windows\NTDS\ntds.dit) and establishing the local Kerberos Key Distribution Center (KDC) *(See Appendix A: Figure 2)*.
3. **Client DNS Alignment & Domain Joining:** To facilitate resource discovery (SRV locator records), the client workstation's primary DNS resolver was explicitly pointed to the DC (192.168.10.10). The workstation relinquished its local security boundary and joined bibek.local through administrative credential verification (bibek\Administrator), creating a computer account object and establishing a machine trust relationship *(See Appendix A: Figure 3)*.

Phase 2: Organize the Company (OUs, Users, & Groups)

To abandon flat directory layouts, an administrative directory tree was constructed within Active Directory Users and Computers (dsa.msc):

1. **Organizational Units (OUs):** Segregated administrative boundaries were created: HR_Department and IT_Department.
2. **User Creation & Attribute Population:** Employee user identity Prakash shah was generated inside the HR_Department OU with complete LDAP attributes (User Principal Name: Prakash shah@bibek.local, title, department, contact records) *(See Appendix A: Figure 4)*.
3. **Role-Based Access Control (RBAC):** To adhere strictly to the principle of least privilege, direct assignment of permissions to user accounts was banned. A Global Security Group named HR_Data_Access was provisioned, and the user Prakash shah was assigned membership *(See Appendix A: Figure 5)*. No administrative privileges (Domain Admins / Enterprise Admins) were granted.

Phase 3: Secure the Data (SMB & NTFS Security)

To decommission uncontrolled local document storage on endpoint endpoints, a centralized file share was established on the storage volume:

1. **Volume & Share Creation:** A root storage directory C:\CompanyData\HR_salaries was created on AD-SERVER and shared via the Server Message Block (SMB) protocol with a clean share moniker (HR_salaries). Share permissions were configured to grant authenticated access while deferring deep authorization to the NTFS layer.
2. **Discretionary Access Control Lists (NTFS DACLs):**
    - Inheritance from C:\CompanyData was severed, converting inherited entries into explicit permissions.
    - Standard unprivileged groups (Users, Authenticated Users) were completely removed from the DACL.
    - Explicit Modify, Read & Execute, List folder contents, Read, and Write permissions were granted exclusively to the bibek\HR_Data_Access Security Group *(See Appendix A: Figure 6)*.
    - Administrative control was preserved strictly for NT AUTHORITY\SYSTEM and BUILTIN\Administrators.

Phase 4: Enforce the Rulebook (Group Policy & Firewalls)

A central Group Policy Object (GPO) named **"Maximum Security"** was authored in the Group Policy Management Console (gpmc.msc) and linked at the root domain level (dc=bibek,dc=local):

1. **Removable Media Quarantine:**
    - Policy path: Computer Configuration -> Policies -> Administrative Templates -> System -> Removable Storage Access
    - Setting: **All Removable Storage classes: Deny all access**

→

Enabled.

    - This mitigates unauthorized data exfiltration and USB flash memory infection vectors.
2. **Host Firewall Hardening:**
    - Policy path: Computer Configuration -> Policies -> Windows Settings -> Security Settings -> Windows Defender Firewall with Advanced Security

- Configuration: Domain Profile enforced: Inbound connections set to **Block (default)** to enforce strict port hygiene.

3. **Propagation & Verification:** The GPO was pushed and applied on Client02 using administrative execution of gpupdate /force and validated via gpresult /r *(See Appendix A: Figure 7)*.

Phase 5: Cryptographic Authentication Hardening (Kerberos vs. NTLM)

1. **NTLM Deprecation Policy:** Inherent structural vulnerabilities in NT LAN Manager (NTLM)—specifically susceptibility to Pass-the-Hash (PtH) and relay vectors—prompted an administrative mandate to restrict legacy protocols.
2. **GPO Hardening:**
   - Network security: Restrict NTLM: Outgoing traffic to remote servers

→

Set to **Deny all**.

   - Network security: Restrict NTLM: Incoming NTLM traffic

→

Set to **Deny all accounts**.

3. **Kerberos Validation:** When user Prakash shah authenticated against the file share via FQDN/hostname, ticket cache diagnostics using the command klist confirmed that mutual authentication was executed via Kerberos using AES-256-CTS-HMAC-SHA1-96 encryption *(See Appendix A: Figure 8)*.

4. **Verification, Validation & Acceptance Criteria**

Security Objective	**Verification Command / Method**	**Observed Result**	**Status**
Domain Membership	**sysdm.cpl / systeminfo on Client02**	**Joined to bibek.local**	**Passed**
RBAC Authorization	**Logged on as Prakash shah, accessing \\WIN-MPC1MB6K5HT\HR_salaries**	**Folder opens; Read/Write allowed**	**Passed**
Access Control Barrier	**Unassigned test account accessing HR_salaries**	**Access Denied prompt returned**	**Passed**

USB Bus Restriction	**Insertion of Mass Storage Device on Client02**	**Blocked via Administrative Policy**	**Passed**
GPO Consistency	**gpupdate /force on endpoint**	**Success (Computer & User policies applied)**	**Passed**
Cryptographic Protocol	**klist inside interactive PowerShell session**	**AES-256 Kerberos tickets active (krbtgt, cifs)**	**Passed**

5. Conclusion

The Active Directory rebuild has established an enterprise-grade security baseline for Wayne Enterprises. The central points of failure inherent in workgroup environments have been eliminated. Password policies, endpoint restrictions, and cryptographic access parameters are now globally managed and verifiable.

Appendix A: Evidence & Technical Artifacts

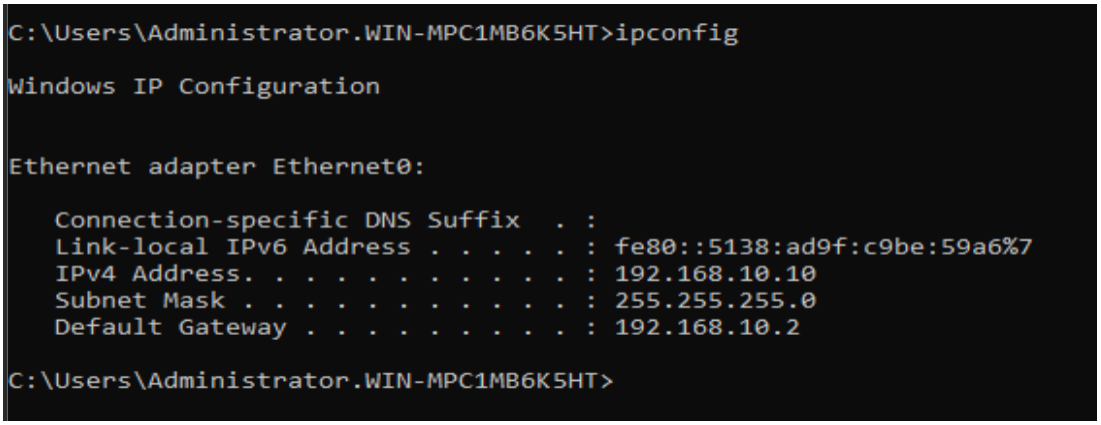


Figure 1: Domain Controller Network & Interface Configuration

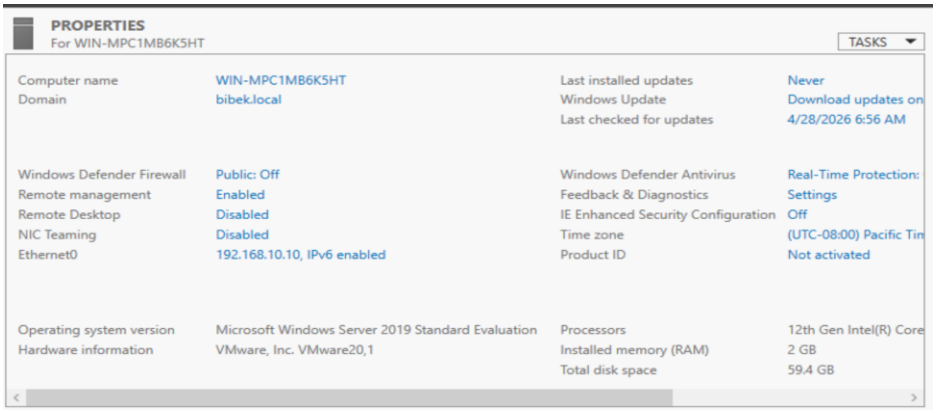


Figure 2: Active Directory Domain Services Promotion Verification

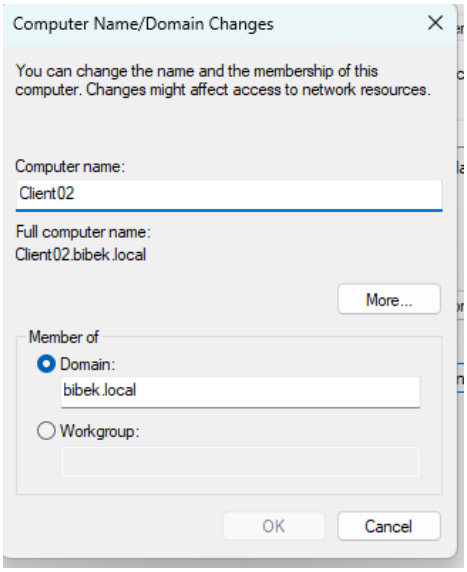


Figure 3: Workstation Domain Join Confirmation.

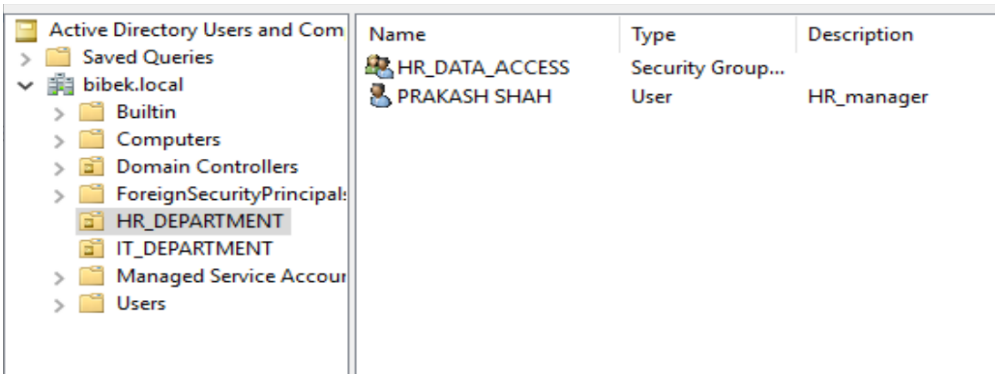


Figure 4: Organizational Unit (OU) & User Identity Architecture.

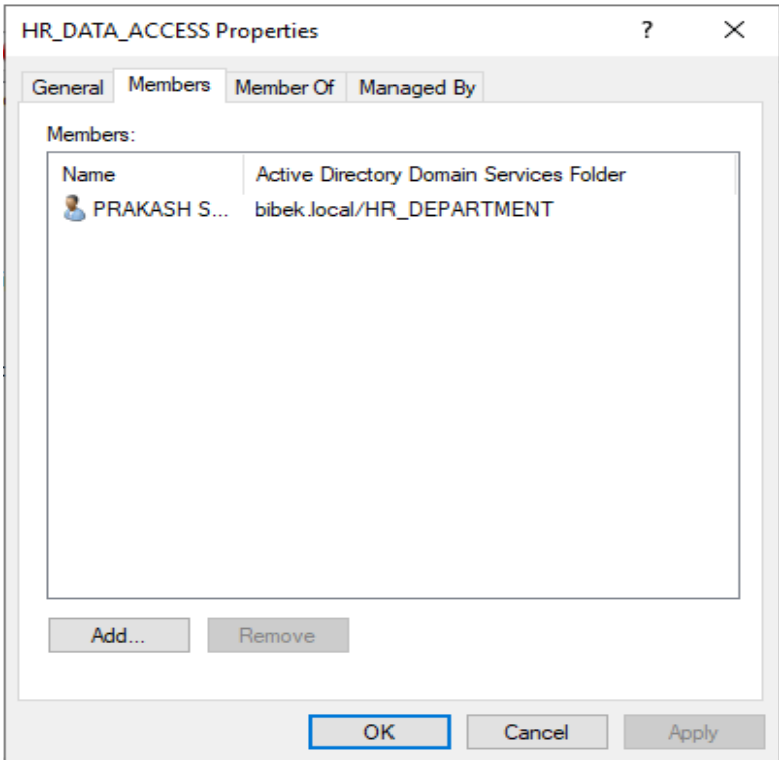


Figure 5: RBAC Security Group Membership Configuration

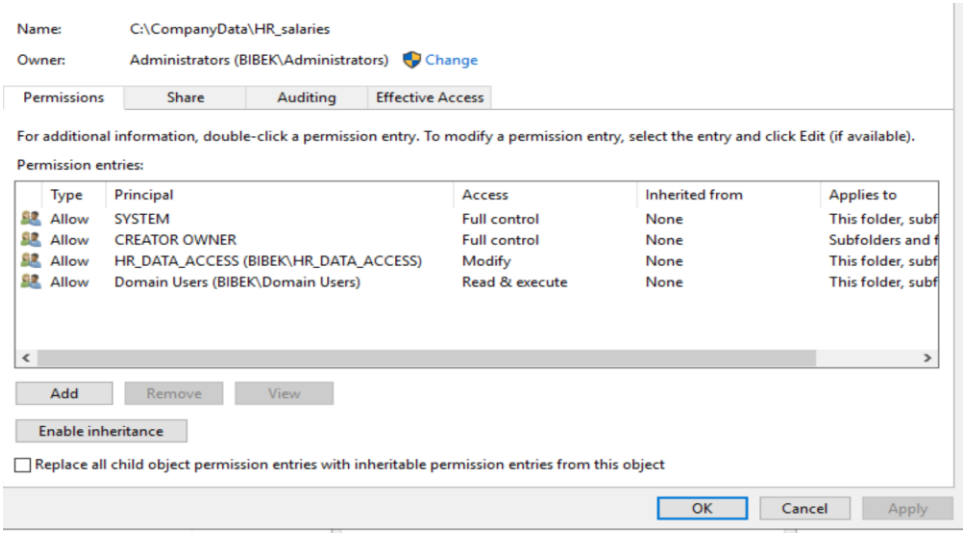
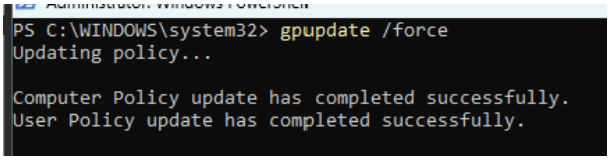


Figure 6: NTFS Discretionary Access Control List (DACL).



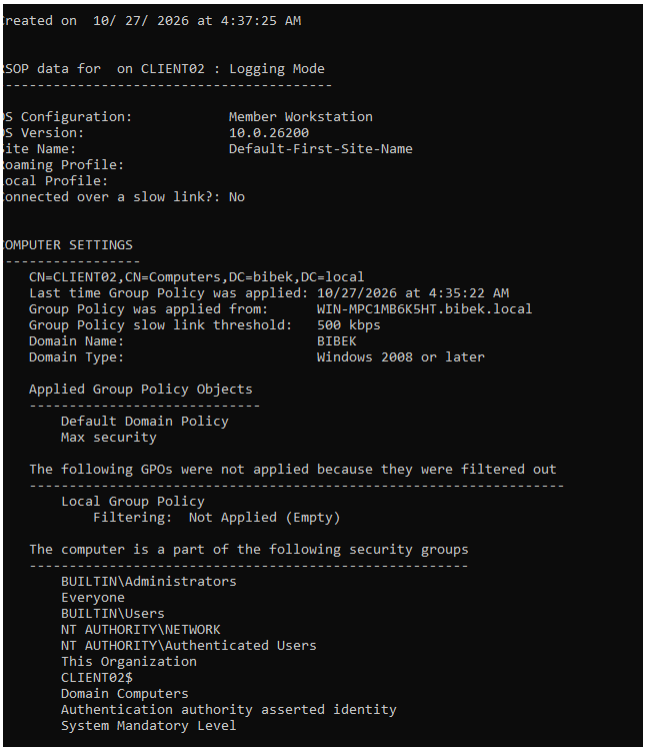


Figure 7: Group Policy Enforcement Output

```
PS C:\WINDOWS\system32> dir \\WIN-MPC1MB6K5HT\HR_Salaries
PS C:\WINDOWS\system32> klist

Current LogonId is 0:0x8b653

Cached Tickets: (5)

#0>     Client: PAKKU @ BIBEK.LOCAL
        Server: krbtgt/BIBEK.LOCAL @ BIBEK.LOCAL
        KerbTicket Encryption Type: AES-256-CTS-HMAC-SHA1-96
        Ticket Flags 0x60a10000 -> forwardable forwarded renewable pre_authent name_canonicalize
        Start Time: 10/27/2026 5:00:26 (local)
        End Time:   10/27/2026 14:58:01 (local)
        Renew Time: 11/3/2026 4:58:01 (local)
        Session Key Type: AES-256-CTS-HMAC-SHA1-96
        Cache Flags: 0x2 -> DELEGATION
        Kdc Called: WIN-MPC1MB6K5HT.bibek.local

#1>     Client: PAKKU @ BIBEK.LOCAL
        Server: krbtgt/BIBEK.LOCAL @ BIBEK.LOCAL
        KerbTicket Encryption Type: AES-256-CTS-HMAC-SHA1-96
        Ticket Flags 0x40e10000 -> forwardable renewable initial pre_authent name_canonicalize
        Start Time: 10/27/2026 4:58:01 (local)
        End Time:   10/27/2026 14:58:01 (local)
        Renew Time: 11/3/2026 4:58:01 (local)
        Session Key Type: AES-256-CTS-HMAC-SHA1-96
        Cache Flags: 0x1 -> PRIMARY
        Kdc Called: WIN-MPC1MB6K5HT

#2>     Client: PAKKU @ BIBEK.LOCAL
        Server: cifs/WIN-MPC1MB6K5HT @ BIBEK.LOCAL
        KerbTicket Encryption Type: AES-256-CTS-HMAC-SHA1-96
        Ticket Flags 0x40a50000 -> forwardable renewable pre_authent ok_as_delegate name_canonicalize
        Start Time: 10/27/2026 5:00:26 (local)
        End Time:   10/27/2026 14:58:01 (local)
        Renew Time: 11/3/2026 4:58:01 (local)
        Session Key Type: AES-256-CTS-HMAC-SHA1-96
        Cache Flags: 0
        Kdc Called: WIN-MPC1MB6K5HT.bibek.local

#3>     Client: PAKKU @ BIBEK.LOCAL
        Server: ldap/win-mpc1mb6k5ht.bibek.local @ BIBEK.LOCAL
        KerbTicket Encryption Type: AES-256-CTS-HMAC-SHA1-96
        Ticket Flags 0x40a50000 -> forwardable renewable pre_authent ok_as_delegate name_canonicalize
        Start Time: 10/27/2026 4:58:35 (local)
        End Time:   10/27/2026 14:58:01 (local)
        Renew Time: 11/3/2026 4:58:01 (local)
        Session Key Type: AES-256-CTS-HMAC-SHA1-96
        Cache Flags: 0
        Kdc Called: WIN-MPC1MB6K5HT.bibek.local

#4>     Client: PAKKU @ BIBEK.LOCAL
        Server: LDAP/WIN-MPC1MB6K5HT.bibek.local/bibek.local @ BIBEK.LOCAL
        KerbTicket Encryption Type: AES-256-CTS-HMAC-SHA1-96
        Ticket Flags 0x40a50000 -> forwardable renewable pre_authent ok_as_delegate name_canonicalize
        Start Time: 10/27/2026 4:58:01 (local)
        End Time:   10/27/2026 14:58:01 (local)
        Renew Time: 11/3/2026 4:58:01 (local)
        Session Key Type: AES-256-CTS-HMAC-SHA1-96
        Cache Flags: 0
        Kdc Called: WIN-MPC1MB6K5HT.bibek.local
```

Figure 8: Active Kerberos Ticket Inspection (klist)